CROYDON

Final Internal Audit Report

Cyber Security Audit

June 2021

Distribution: Interim Executive Director of Resources and Deputy Monitoring Officer

Chief Digital Officer

Head of Digital Operations

Assurance Level	Issues Identified	
Limited Assurance	Priority 1	1
	Priority 2	6
	Priority 3	2

Confidentiality and Disclosure Clause

This report ("Report") was prepared by Mazars LLP at the request of London Borough of Croydon and terms for the preparation and scope of the Report have been agreed with them. The matters raised in this Report are only those which came to our attention during our internal audit work. Whilst every care has been taken to ensure that the information provided in this Report is as accurate as possible, Internal Audit have only been able to base findings on the information and documentation provided and consequently no complete guarantee can be given that this Report is necessarily a comprehensive statement of all the weaknesses that exist, or of all the improvements that may be required.

The Report was prepared solely for the use and benefit of London Borough of Croydon and to the fullest extent permitted by law Mazars LLP accepts no responsibility and disclaims all liability to any third party who purports to use or rely for any reason whatsoever on the Report, its contents, conclusions, any extract, reinterpretation, amendment and/or modification. Accordingly, any reliance placed on the Report, its contents, conclusions, any extract, reinterpretation, amendment and/or modification by any third party is entirely at their own risk.

Please refer to the Statement of Responsibility in Appendix 3 of this report for further information about responsibilities, limitations and confidentiality.

mazars

Contents

Page

Executive Summary

1. Introduction 2
2. Key Issues 2

Detailed Report

3. Actions and Key Findings/Rationale 4
4. Priority 3 Issues 11

Appendices

1. Terms of Reference
2. Definitions for Audit Opinions and Issues Identified
3. Statement of Responsibility

1 INTRODUCTION

1.1 In the current climate, a major new cyber security breach globally occurs on a daily basis. Even at large, well-protected organisations, successful cyber-attacks have far reaching economic, reputational, and legal consequences for organisations.

1.2 Ineffective controls over information security and cyber awareness could lead to a compromise of the IT infrastructure, which in turn could lead to a loss of data, and possible legal/regulatory breaches (e.g. GDPR). The Council has an internal IT/Digital team but continues to be reliant on third party IT service providers including a legacy (albeit reducing in size) provision from Capita, which supports the network and firewall infrastructures and more recently providers such as Littlefish, which provide local desktop and helpdesk support. Cyber Security is the responsibility of an internal member of staff but again some of the controls are dependent on Capita and Littlefish.

1.3 This audit will be split into two stages as follows:

- Cyber Security Governance and Protection – this phase of the audit will occur during 2020-21 financial year and will leverage an anonymised set of key findings (good practices and areas for improvement) from Mazars internal IT audits of cyber security since the beginning of 2020 and the emerging themes arising from the Covid-19 lockdowns. This will primarily focus on Cyber related governance and protective controls. The objective being to focus the audit specifically on key themes noted elsewhere which are common across peer groups; and
- Cyber Security Detection, Response and Resolution – this phase of the audit will (a) follow up the findings from the above phase and (b) focus on Cyber related detective, response and resolution controls and will be conducted during 2021-22 financial year.

1.4 This audit addresses the first of the two stages and is being undertaken as part of the agreed Internal Audit Plan for 2020/21. The fieldwork for this review was completed during the government measures put in place in response to Covid-19. Consequently, testing was performed remotely. However, we have been able to obtain all relevant documents required for the review and cover all planned areas in the scope remotely

2. Key Issues

Priority 1 Issue
The Council has not undertaken recent penetration testing across the network and infrastructures. Such testing is commonly undertaken by the Council's peers at least annually and more frequently if significant changes are proposed to the IT environment. (**Issue 1**)

Priority 2 Issues
Compared with local government peers, the Council has insufficient resources dedicated to the execution of cyber/information security responsibilities. Currently the Council has one dedicated member of staff compared with many other organisations having at least three or four team members. **(Issue 2)**
Cyber/Information Security awareness reminders and notifications are issued via Council newsletters and emails but these tend to be unstructured and not necessarily formally scheduled on a regular basis. This is exacerbated by the lack of a Cyber Security awareness training programme although the Digital Security Officer was in the process of developing a programme during our audit. **(Issue 3)**
Many organisations including those in local government have or plan to undertake regular 'phishing' exercises, however, the Council has not undertaken or have plans to do the same. **(Issue 4)**
The Council is reliant on Capita as an IT service provider and thus is also reliant on this service provider for the effective management of related cyber security risks. However, the Council was unable to obtain evidence of some of the controls that Capita have implemented to manage such risks. **(Issue 5)**
Privileged/administrator-based accounts across infrastructures have been reviewed in the past including most recently Active Directory Domain Admin reviews in March 2020 and Azure and Office365 admin reviews in August 2020. However, these are neither formally scheduled to occur at pre-determined frequencies nor undertaken regularly enough. **(Issue 6)**
There is no timeframe defined in any policy/documentation which triggers firewall rules which are no longer needed to be disabled or removed. **(Issue 7)**

Priority 3 recommendations are included under item 4 below.

3. Actions and Key Findings/Rationale

Audit Area: Penetration Testing

Priority	Action Proposed by Management	Detailed Finding/Rationale – Issue 1
1	We will conduct penetration testing within the 2021/22 financial year.	The Council has not undertaken recent penetration testing across the network and infrastructures. Such testing is commonly undertaken by the Council's peers at least annually and more frequently if significant changes are proposed to the IT environment. Penetration testing is an authorised test of a system, network or infrastructure designed to identify security vulnerabilities/weaknesses so that these can be fixed. It is a core tool for analysing security but should not be considered a 'magic bullet' as the test can only validate that your organisation's systems, network or infrastructures are not vulnerable to known issues on the day of the test. Therefore, it is also important for any organisation that undertakes penetration testing to follow up on the results of the test, ensuring that action plans are developed and implemented for detected vulnerabilities.

Management Response	Responsible Officer	Deadline
The Council is still in an early stage of embedding its cyber security hygiene and has a clear plan for the steps and issues that it needs to address. Although recently there has not been penetration testing we have implemented regular vulnerability scanning and reporting and are aiming for a full IT health check and pen test within 2021/22	Digital Security Officer	March 2022

Audit Area: Resources

Priority	Action Proposed by Management	Detailed Finding/Rationale – Issue 2
2	Recruiting an additional role of Incident and Security Officer to support the current Cybersecurity Officer on implementation and monitoring of cybersecurity mitigations. This post was created in our recent restructure of the division.	Compared with local government peers, the Council has insufficient resources dedicated to the execution of cyber/information security responsibilities. Currently the Council has one dedicated member of staff compared with many other organisations having at least three or four team members. With insufficient resources available, the Council is likely to take a 'best endeavours' or reactive approach to managing risks in regard to cyber security and therefore increases the likelihood that such risks will materialise in the future.

Management Response	Responsible Officer	Deadline
LBC has a cyber security lead who is driving a change in behaviour throughout the organisation. As such, every employee has a responsibility to enhance cyber security across the council. Within the CDS restructure we have also added an additional incident and security officer post to bolster the resources. This post is also highly supported by the technical architecture team and Service Operations Team who liaise regularly and collaborate on a number of areas and projects to drive the forward plan. We currently have a supplier that also provides additional resource and expertise on key areas. There is an information management team that exists within the council which is formed of 3 individuals also.	Head of Digital Operations	November 2021 to recruit new post (likely to complete sooner, but allowing for 2 rounds of recruitment in case not successful on first campaign).

Audit Area: Cyber Security Awareness Programme

Priority	Action Proposed by Management	Detailed Finding/Rationale – Issue 3
2	We plan to roll-out mandatory cyber security training to all staff by the end of July 2021.	Cyber/Information Security awareness reminders and notifications are issued via Council newsletters and emails but these tend to be unstructured and not necessarily formally scheduled on a regular basis. This is exacerbated by the lack of a Cyber Security awareness training programme, although the Digital Security Officer was in the process of developing a programme during our audit. It is now common for staff to be perceived as the 'weak link' in an organisation's cyber security defence. Most organisations and specifically in local government now have regular cyber security awareness training. Such training captures staff at induction but also as part of a regular refresher. A regular refresher of awareness is important as cyber security threats and risks constantly emerge or change.

Management Response	Responsible Officer	Deadline
There is a link within the existing mandatory information management training which refers to cyber security but it has been deemed insufficient. Cyber security training has been acknowledged as a key part of driving the council's forward plan and we plan to roll-out mandatory cyber security training to all staff by the end of July 2021. Additionally cyber awareness is being improved via process and embedding security into key areas to assist with driving change and working with colleagues to enhance their understanding of their responsibilities. This is not the planned approach going forward.	Digital Security Officer	August 2021

Audit Area: Phishing Simulation Programme

Priority	Action Proposed by Management	Detailed Finding/Rationale – Issue 4
2	Procure a phishing simulator tool that works well in our infrastructure; and include phishing awareness in mandatory training by July 2021	Many organisations including those in local government have or plan to undertake regular 'phishing' simulations with their staff, however, the Council has not undertaken or does not have plans to do the same. Phishing is an attack method adopted by hackers where untargeted, mass emails are sent to many people asking for sensitive information (such as bank details) or encouraging them to visit potentially fake websites. This method has increased in use during the last 18 months and has become commonly successful, most notably in the public sector and in local government particularly. More than 90% of the cyber attacks and data breaches that occur are due to phishing emails as employees are often unable to differentiate between malicious and legitimate emails.

Management Response	Responsible Officer	Deadline
LBC undertook a pilot phishing campaign last year, however the software was not renewed as it was incompatible with the infrastructure. It is recognised that there is a need to continue this in the future and are currently speaking with multiple suppliers for a suitable product. Additionally, phishing awareness is included the mandatory training scheduled to take place in July 2021, this is a short term fix until we have a more permanent solution	Digital Security Officer	July 2021 for awareness training By March 2022 for having capability to run regular phishing simulation test.

Audit Area: Reliance on IT Service Provider for management of cyber risks

Priority	Action Proposed by Management	Detailed Finding/Rationale – Issue 5
2	Continue to work with Capita to improve visibility of their controls.	The Council is reliant on Capita as an IT service provider and thus is also reliant on this service provider for the effective management of related cyber security risks. However, the Council was unable to obtain evidence of some of the controls that Capita have implemented to manage such risks. Examples of controls not evidenced as tested include: • Build documentation for physical and virtual servers that support appropriate security is built into infrastructures from the outset; • Active Directory account removal procedures; • Firewall policy. Although it is not uncommon for an organisation to be reliant on a service provider for IT and also the management of related cyber risks and controls, it is common for organisations including those in local government to: • Have the right to audit as part of their contract with the service provider; • Obtain regular and formal assurances from the service provider on the management and control of cyber related risks. Such assurances can be in the form of a Service Organisation Control (SOC) 2 report, ISO27001 certifications and/or Cyber Essentials Plus.

Management Response	Responsible Officer	Deadline
There are a number of projects set up to tackle these issues and improve LBC's visibility in these areas. All are large pieces of work that require resource and are in the pipeline of work to be completed.	Head of Digital Operations	Ongoing. At least by May 2022 when contract ends (the issue at hand will be addressed as reprocure/renegotiate).

Audit Area: Privileged/administrator account reviews

Priority	Action Proposed by Management	Detailed Finding/Rationale – Issue 6
2	Continue with our cybsercurity work plan to address this issue throughout 2021	Privileged/administrator accounts across infrastructures have been reviewed in the past, including most recently Active Directory Domain Admin reviews in March 2020 and Azure and Office365 admin reviews in August 2020. However, these are neither formally scheduled to occur at pre-determined frequencies nor undertaken regularly enough. Privileged access is the route to an organisation's critical assets because they carry elevated rights that standard users do not commonly have. Such elevated rights should be used only for justified purposes and in some organisations are only provided based on an incident or change ticket via the service desk. It is acknowledged that such practices are not effective for some organisations in maintaining service delivery, therefore frequent reviews of those users with elevated rights helps ensure that only appropriate users have such access and only for as long as is necessary. It is also noted that unused and/or dormant privileged accounts can be targeted by hackers and if compromised can be used to traverse the network as part of their reconnaissance.

Management Response	Responsible Officer	Deadline
As stated, work on privileged accounts has started and will continue throughout 2021. Once we have completed the initial 'clean-up' phase of this process we will implement regular scheduled reviews of all privileged accounts across our estate. Work as also started on reviewing & updating existing policy and standards relating to 3rd party access, leavers & starters, retention periods.	Head of Digital Security	Clean up will be completed and regular reviews will be scheduled by March 2022.

Audit Area: Firewall Rule Review

Priority	Action Proposed by Management	Detailed Finding/Rationale – Issue 7
2	We will put this in place.	There is no timeframe defined in any policy/documentation which triggers firewall rules which are no longer needed to be disabled or removed. As noted in Issue 1 above, penetration testing only identifies security vulnerabilities on the day of the test and therefore does not provide ongoing assurance that security vulnerabilities are not introduced and if so, are detected in a timely manner. Due to constant change and the growing number of threats facing organisations, firewall security must continuously adapt to combat existing threats. Due to standards such as PCI-DSS and ISO27001, reviews of firewall rules are increasingly important. Even if an organisation does not need to meet these standards, the organisation may need to demonstrate that the network is secure for relationships with specific partners or customers.

Management Response	Responsible Officer	Deadline
This has been recognised by the organisation and we are currently working on reviewing/amending all firewalls configurations, policies & documentation, the project is due to complete August 2021.	Head of Digital Security	August 2021

4. Priority 3 Issues

Action Proposed by Management	Detailed Finding/Rationale
Information Security Management System (ISMS) 1) Given LBC's current climate & its cyber infancy this has been deemed a low priority with the high risk factors that have been identified. However within the cyber security forward plan we aim to do a full cybersecurity 'core' document review in Q1 2022.	Although the Council has a well-defined organisational structure in place, the ISMS document is out of date (last updated 29 November 2019). The ISMS helps the organisation to define roles and responsibilities of individuals and the organisation itself responsible for cyber security.
Information/Cyber Security related policies 2) As stated above we plan a full cybersecurity document review in Q1 2022 which will then become an annual review of all cyber policies, processes & controls.	The Council has policies in place addressing information and cyber security related processes and controls. However, these are not updated on a regular basis. Policies should be reviewed and updated on a regular basis to ensure they address emerging and changing threats or risks.

Appendix 1

AUDIT TERMS OF REFERENCE
Cyber Security – 2020/21

1 INTRODUCTION

1.1 In the current climate, a major new cyber security breach occurs on a daily basis. Even at large, well-protected organisations, cyber-attacks have far reaching economic, reputational and legal consequences for organisations.

1.2 Ineffective controls over information security and cyber awareness could lead to a compromise of the IT infrastructure, which in turn could lead to a loss of data, and possible legal/regulatory breaches (e.g. GDPR).

1.3 This audit is being undertaken as part of the agreed Internal Audit Plan for 2020/21.

2 OBJECTIVES AND METHOD

2.1 The overall audit objective is to provide an objective independent opinion on the adequacy and effectiveness of controls / processes.

2.2 The audit will for each controls / process being considered:

- Walkthrough the processes to consider the key controls;
- Conduct sample testing of the identified key controls, and
- Report on these accordingly.

3 SCOPE

3.1 The audit examined the Council's arrangements for cyber security and was split into two stages as follows:

3.2 This audit will be split into two stages as follows:

- Cyber Security Governance and Protection – this phase of the audit will occur during 2020-21 financial year and will leverage an anonymised set of key findings (good practices and areas for improvement) from Mazars internal IT audits of cyber security since the beginning of 2020 and the emerging themes arising from the Covid-19 lockdowns. This will primarily focus on Cyber related governance and protective controls. The objective being to focus the audit specifically on key themes noted elsewhere which are common across peer groups; and
- Cyber Security Detection, Response and Resolution – this phase of the audit will (a) follow up the findings from the above phase and (b) focus on Cyber related detective, response and resolution controls and will be conducted during 2021-22 financial year.

Cyber Security 2020-21

Audit Area	Identified Issues		
	Priority 1 (High)	Priority 2 (Medium)	Priority 3 (Low)
Governance, Culture, Awareness and User Education	0	3	2
Configuration/IT Service Providers	0	1	0
Network Security & Firewalls	1	1	0
Identity and Access Management	0	1	0
Totals	**1**	**6**	**2**

Appendix 2

Definitions for Audit Opinions and Identified Issues

In order to assist management in using our reports:

We categorise our **audit assurance opinion** according to our overall assessment of the risk management system, effectiveness of the controls in place and the level of compliance with these controls and the action being taken to remedy significant findings or weaknesses.

	Full Assurance	There is a sound system of control designed to achieve the system objectives and the controls are constantly applied.
	Substantial Assurance	While there is basically a sound system of control to achieve the system objectives, there are weaknesses in the design or level of non-compliance of the controls which may put this achievement at risk.
	Limited Assurance	There are significant weaknesses in key areas of system controls and non-compliance that puts achieving the system objectives at risk,
	No Assurance	Controls are non-existent or extremely weak, leaving the system open to the high risk of error, abuse and reputational damage.

Priorities assigned to identified issues are based on the following criteria:

Priority 1 (High)	Fundamental control weaknesses that require immediate attention by management to action and mitigate significant exposure to risk.
Priority 2 (Medium)	Control weakness that still represent an exposure to risk and need to be addressed within a reasonable period.
Priority 3 (Low)	Although control weaknesses are considered to be relatively minor and low risk, still provides an opportunity for improvement. May also apply to areas considered to be of best practice that can improve for example the value for money of the review area.

Appendix 3

Statement of Responsibility

We take responsibility to the London Borough of Croydon for this report which is prepared on the basis of the limitations set out below.

The responsibility for designing and maintaining a sound system of internal control and the prevention and detection of fraud and other irregularities rests with management, with internal audit providing a service to management to enable them to achieve this objective. Specifically, we assess the adequacy and effectiveness of the system of internal control arrangements implemented by management and perform sample testing on those controls in the period under review with a view to providing an opinion on the extent to which risks in this area are managed.

We plan our work in order to ensure that we have a reasonable expectation of detecting significant control weaknesses. However, our procedures alone should not be relied upon to identify all strengths and weaknesses in internal controls, nor relied upon to identify any circumstances of fraud or irregularity. Even sound systems of internal control can only provide reasonable and not absolute assurance and may not be proof against collusive fraud.

The matters raised in this report are only those which came to our attention during the course of our work and are not necessarily a comprehensive statement of all the weaknesses that exist or all improvements that might be made. Recommendations for improvements should be assessed by you for their full impact before they are implemented. The performance of our work is not and should not be taken as a substitute for management's responsibilities for the application of sound management practices.

This report is confidential and must not be disclosed to any third party or reproduced in whole or in part without our prior written consent. To the fullest extent permitted by law Mazars LLP accepts no responsibility and disclaims all liability to any third party who purports to use or rely for any reason whatsoever on the Report, its contents, conclusions, any extract, reinterpretation amendment and/or modification by any third party is entirely at their own risk.

Registered office: Tower Bridge House, St Katharine's Way, London E1W 1DD, United Kingdom. Registered in England and Wales No 0C308299.